

4 - Solution Architecture

🕒 Created	June 24, 2026 1:15 AM
🏷️ Tags	

Thuộc tính	Dụng cụ	Nó làm gì (1 câu)
Authenticity	Chữ ký số bất đối xứng (private ký / public verify)	Chứng minh "ai tạo ra" mà không lộ khóa ký
Authenticity	Key-set công bố (JWKS, mỗi khóa có <code>kid</code>)	Phát khóa công khai cho bên verify; hỗ trợ xoay khóa
Authenticity	mTLS (TLS hai chiều)	Hai máy xác thực lẫn nhau bằng certificate
Integrity	MAC (Message Authentication Code, ví dụ HMAC) – khóa đối xứng chung	Bên gửi tính một "dấu niêm phong" từ nội dung; bên nhận tính lại, khác = bị sửa
Integrity	Hash (SHA-256)	"Dấu vân tay" của dữ liệu; đổi 1 bit → hash khác hẳn
Integrity	Chữ ký số	Vừa bảo đảm toàn vẹn vừa xác thực nguồn gốc (mạnh hơn MAC, chậm hơn)
Non-repudiation	Chữ ký số (bằng khóa riêng của chủ thể)	Chỉ chủ thể sở hữu khóa mới tạo được → khó chối bỏ hành động
Non-repudiation	Audit log bất khả sửa (append-only)	Lưu dấu vết không thể xóa/sửa mà không bị phát hiện
Confidentiality	TLS (mã hóa đường truyền)	Chống nghe lén khi dữ liệu đang truyền
Confidentiality	Mã hóa at-rest	Dữ liệu lưu trong kho cũng được mã hóa
Confidentiality	Secret Manager + Least Privilege	Kho khóa tập trung; mỗi service chỉ đọc đúng secret cần thiết
Availability	Rate Limiting	Giới hạn số request theo nguồn hoặc theo khoảng thời gian
Availability	Validation rẻ trước, crypto đắt sau	Loại request rác trước khi tốn CPU cho verify chữ ký hoặc giải mã
Authorization	Scope / RBAC (Role-Based Access Control)	Token mang quyền; endpoint kiểm tra quyền trước khi thực hiện

Thuộc tính	Dụng cụ	Nó làm gì (1 câu)
Authorization	Kiểm quyền ở mọi tầng (Gateway + Backend)	Không tin tưởng mù quáng; áp dụng tư duy Zero Trust
Chống Replay (Integrity + Freshness)	Nonce (dùng một lần) + Timestamp	Nonce: "đã dùng rồi → từ chối"; Timestamp: "quá cũ → từ chối"

Cơ chế cho từng mục tiêu

MT	Cơ chế chọn	Tại sao cơ chế này
AUTHN	Chữ ký bất đối xứng + key-set công bố; mTLS	IdP giữ khóa riêng để ký, gateway chỉ giữ khóa công khai để verify
INTEG	MAC (HMAC) trên toàn body + nonce + timestamp	MAC dùng khóa bí mật (đã cấp cho M2M) để khóa body, nếu gateway tính lại bị lệch = bị sửa, rò + nhanh hơn signature. Nonce + timestamp bắt mỗi request chỉ có hiệu lực mỗi lần trong time window
NONREP	Chữ kí số bất đối xứng + audit log append only	chỉ chủ thể giữ khóa riêng → bằng chứng không giả được → không chối được, và log sẽ được ghi thêm vào (append only) và không thể xóa hay sửa
CONF	TLS + Mã hóa at-rest + Secret Manager + Least Privilege	Dùng TSL để mã hóa trên đường truyền tránh bị sniff, dữ liệu lưu trên secret store cũng phải mã hóa, và least-privilege trị "nội bộ ai cũng đọc được", gateway không giữ secret
AVAIL	Rate-limiting (per-IP cho lưu lượng chưa xác thực + per-client/user cho đã xác thực) + Validation rò trước, crypto đặt sau	Giới hạn truy cập theo IP tránh flood, đặt các kiểm rò (format, exp, timestamp, nonce) trước verify chữ ký
AUTHZ	Scope / RBAC + Kiểm quyền ở mọi tầng (Gateway + Backend) , backend chỉ tin quyền đến từ nguồn có chữ ký (token gốc / claim được ký), không tin header trần	token user gọi endpoint admin → thiếu scope → 403, giả X-Roles → header trần không có chữ ký → bị loại

NET: Fix flat-trust

Cửa	Nối 2 vùng	Control
1	Internet → Gateway	TLS + rate-limit
2	Gateway → Backend	mTLS
3	Gateway → Secret Store	TLS + least-privilege

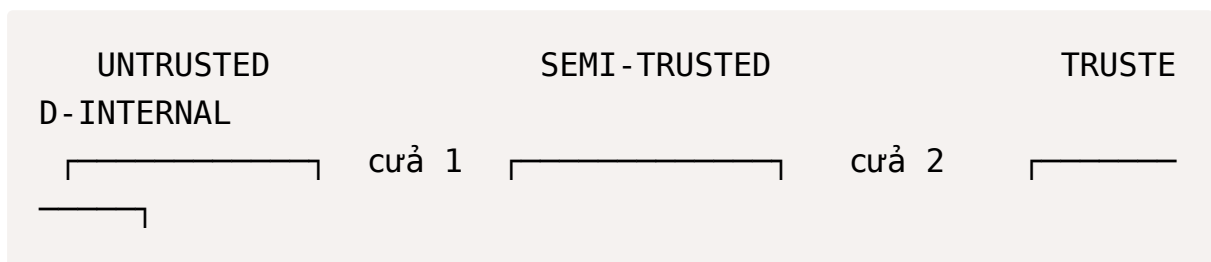
HOST: isolation & secret

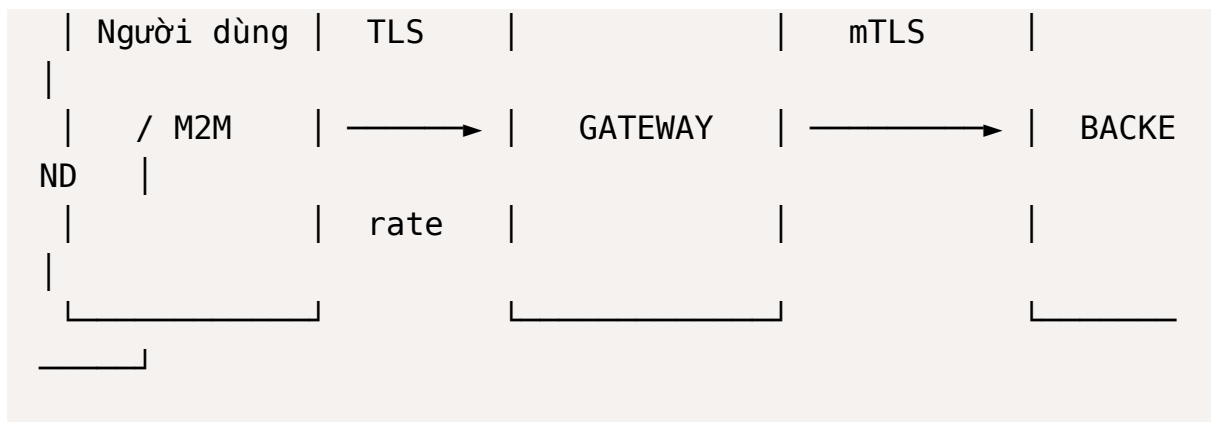
Thành phần	Chạy cô lập	Bí mật nó cần và sống ở đâu ?
Gateway	Cô lập, chỉ mở cổng cho cửa 1	Public key (verify token) + Secret HMAC + nạp từ secret store lúc chạy, không ghi vào image
Backend	Cô lập với Internet, chỉ nhận kết nối từ vùng Gateway (cửa 2)	Khóa riêng + chứng chỉ mTLS của nó → nạp từ secret store, không ghi vào image. Material để verify (CA/IdP public key) = công khai
Secret Store	Cô lập, chỉ vùng được phép chạm	Là kho của secret, least-privilege từng service

APP + DATA FLOW

1. Rate-limit: quá ngưỡng → 429
2. Token, đúng định dạng: thiếu → 401
3. exp/timestamp: hết hạn → 401
4. nonce: đã sử dụng → 401
5. HMAC body khớp sai hash → 401
6. Verify chữ ký token: sai role → 401
7. Scope/role: sai → 403
8. zero-trust (verify token gốc/claim ký + re-check scope): 401/403

Luồng REQUEST + vùng tin cậy (tầng Net)





Luồng SECRET (tầng Host) -về hub, KHÔNG đi qua backend

